Kong: secure an API (stretch)

For Dhirendra Solanki, from iSteer Technologies

Alongside your Flogo slides, this hands-on step shows how far you can take a new platform. Publish a fictitious Orders API through Kong Gateway and secure it. The levels form a ladder: go as far as you can; the top levels are meant to be hard. We look at the level you reach running live, and how well you explain the concepts and answer questions.

Levels

Level	Task
Start	Your starting point and learning plan, written on day 1 in your repo.
L1	Kong Gateway with Kong Manager; an Orders API (any mock upstream) with service, routes and consumers; all configuration as code with decK in Git.
L2	Authentication and authorisation: API key, JWT (RS256, your own keys), OAuth 2.0 client credentials, HMAC, ACL groups. No secrets in Git.
L3	Transport and traffic protection: TLS, per-consumer rate limits, request size, IP allow / deny, bot detection, CORS, header hygiene, maintenance block, timeouts and retries.
L4	Security monitoring: dashboard of 401 / 403 / 429 / 5xx, traces, audit log; your OWASP API Security Top 10 (2023) map.
L5	Kubernetes: Kong Ingress Controller on a local cluster, routes as Gateway API resources, the same security.
L6	Automation: Kong configuration generated from an OpenAPI spec, a CI pipeline (validate, diff, sync), a canary release of v2.
L7	AI gateway: Kong in front of a local open model (Ollama) with prompt guard, authentication and limits.

What we look at

- The level you reach, running live, and why you chose each control.
- Concepts without notes: JWT, OAuth 2.0, TLS, rate limiting, Kubernetes Gateway API, what a gateway cannot stop.
- Your plan from day 1, a daily learning log and commits as you go.
- In the demo: an attack script showing each control block a bad request, and a change we ask for on the spot.

Dates

- Mon 16 Nov: tell Thabitha your preferred time on Fri 20 Nov.
- Thu 19 Nov, 6 pm: repo link (private, shared with us), this template and your slides; earlier is welcome.
- Fri 20 Nov: one session of one hour: 30 minutes for your slides and live demo, then our questions and a change we ask for, a few questions on your Flogo slides, and a short one-to-one. Questions before then: Thabitha Konda (HR).

What you can use

Open-source tools only: Kong Gateway open source 3.9 (Docker image kong:3.9) with Kong Manager OSS and decK, Kong Ingress Controller, kind, Docker, Prometheus, Grafana, an OpenTelemetry collector with Jaeger, Ollama with an open model; GitHub (free) for the repo and Actions. No trials or Enterprise licences are needed; Enterprise features are explained, not built. Docs: developer.konghq.com. No customer data. AI tools are allowed; you must explain every step.

Your answers

Name: Date sent:

Fill the sections for the levels you reach. Short answers are fine; the repo and the demo carry the detail.

Section 1: Starting point and learning plan

Write this on day 1 in your repo, then keep the log daily.

Hints: Be honest about where you start; we compare this plan with what you actually did. Name real sources.

Item	Your answer
What you know today: API gateways, Kong, Docker, Kubernetes, OAuth 2.0 / JWT, TLS, CI, LLMs (none / read / used)	
Your plan: what you learn when, and the sources	
Your learning log: link and how you kept it	

Section 2: L1: Kong running, configuration as code

Install Kong Gateway and publish the Orders API. Any mock upstream is fine.

Hints: Kong docs (developer.konghq.com): get started with Docker, services and routes, consumers, decK. Kong Manager runs on port 8002.

Item	Your answer
How you run Kong (Docker compose / VM), database or DB-less, versions	
Service, routes, consumers: what you created and why	
decK: how configuration flows from Git to Kong	
Repo link and the one command to bring everything up	

Section 3: L2: Authentication and authorisation

Protect the routes and decide which client uses which method.

Hints: Plugins: key-auth, jwt, oauth2, hmac-auth, acl. Think about where each credential lives and how it is rotated.

Item	Your answer
Which authentication on which route, and why	
JWT: algorithm, key handling, claims checked	
OAuth 2.0: grant, token endpoint, scopes, token lifetime	
Authorisation: ACL groups and who can do what	
Secrets: where keys, secrets and certificates live	

Section 4: L3: Transport and traffic protection

Encrypt, limit and harden.

Hints: Plugins: rate-limiting, request-size-limiting, ip-restriction, bot-detection, cors, response-transformer, request-termination. Certificates and SNIs for TLS; service settings for timeouts and retries.

Item	Your answer
TLS: proxy certificate, upstream TLS, protocols	
Rate limits: per what, window, policy, response	
Request size, IP allow / deny, bot detection, CORS	
Header hygiene and maintenance block	
Timeouts and retries: values and why	

Section 5: L4: Security monitoring and coverage

Show attacks on a dashboard and map what the gateway covers.

Hints: Plugins: prometheus, opentelemetry, file-log or http-log. OWASP API Security Top 10 2023: owasp.org.

Item	Your answer
Dashboard: panels and what each tells you	
Traces and audit log	
OWASP API Security Top 10 (2023): what Kong covers, how, and what it cannot	
Enterprise-tier features (knowledge only): what each adds and when a customer needs it	
Mashery to Kong (one slide)	

Section 6: L5: Kubernetes

Run the same API and security on a local Kubernetes cluster.

Hints: Kong Ingress Controller docs; kind for the cluster; Kubernetes Gateway API (Gateway, HTTPRoute); KongPlugin and KongConsumer resources.

Item	Your answer
Cluster and install: tool, Kong Ingress Controller version, how installed	
Routes and plugins as resources	
What changed against L1-L4 and why	

Section 7: L6: Automation and API-first

Generate configuration from an API spec, deploy it through a pipeline and release v2 safely.

Hints: decK: deck file openapi2kong, deck file validate / lint, deck gateway diff and sync. GitHub Actions free tier. Upstreams and weighted targets.

Item	Your answer
OpenAPI to Kong: spec, command, what you added by hand	

Pipeline: steps and what blocks a merge	
Canary: how traffic moves to v2 and how you roll back	

Section 8: L7: AI gateway

Put Kong in front of an LLM and protect it.

Hints: Plugins: ai-proxy, ai-prompt-guard, ai-prompt-decorator. Ollama (open source) runs an open model locally.

Item	Your answer
Model and route: which LLM, how Kong reaches it	
Protection on the AI route	
Prompt injection: what the gateway can and cannot do	

Section 9: Demo (Fri 20 Nov)

30 minutes in all. Up to 8 slides: architecture, the controls and why, your OWASP map, what you learned and how. Then the live demo and the attack script.

Slot booked for (date and time):